

# Data Protection and AI Governance Policy

Document owner: Compliance  
Department: Legal and Compliance  
Version: 2026.1  
Effective date: 2026-01-01

Document owner: Compliance Department: Legal and Compliance Version: 2026.1 Effective date: 2026-01-01

## Purpose

This policy governs how TraceStock AI handles personal data, what automated systems and AI agents may access, what they must never do, and how their decisions are reviewed. It applies to every system that reads company data, including analytics tooling and conversational agents, and to every employee, contractor, and processor acting on the company's behalf.

The company operates in Germany and serves customers across the European Union. The General Data Protection Regulation applies to everything described here, and the German Federal Data Protection Act applies alongside it. Where this policy is stricter than the law, this policy applies. Where the law is stricter, the law applies.

## Legal Bases for Processing

Every processing activity must rest on a lawful basis, identified before the processing begins rather than justified afterwards.

| Activity                              | Lawful basis                            |
|---------------------------------------|-----------------------------------------|
| Fulfilling an order                   | Performance of a contract               |
| Processing a return or refund         | Performance of a contract               |
| Retaining transaction records         | Legal obligation, tax law               |
| Handling a support case               | Performance of a contract               |
| Fraud prevention and review           | Legitimate interests                    |
| Web analytics and traffic measurement | Legitimate interests, with minimisation |
| Marketing communications              | Consent                                 |
| Employee records                      | Contract and legal obligation           |

Legitimate interests require a documented balancing assessment recording the interest pursued, why the processing is necessary, and why it does not override the individual's rights. Where the assessment is finely balanced, consent is obtained instead.

Consent, where used, must be freely given, specific, informed, and as easy to withdraw as to give. Pre-ticked boxes and bundled consent are not valid.

## Scope of Personal Data

The following are treated as personal data and are subject to this policy:

- Customer names, addresses, email addresses, and phone numbers
- Order histories linked to an identifiable person
- Payment references, including partial card identifiers
- Support conversation transcripts
- IP addresses and device identifiers collected by web analytics
- Employee records of any kind
- Supplier contact names and their business contact details

Aggregate figures that cannot be traced to an individual, such as total units sold by category, are not personal data and may be used freely in reporting.

### ***Special category data***

The company does not intentionally collect special category data, meaning data revealing racial or ethnic origin, political opinions, religious beliefs, trade union membership, genetic or biometric data, health data, or data concerning sex life or sexual orientation.

Health data occasionally arrives unsolicited, most often when a customer explains a return by describing a medical condition, or when an employee submits a sickness certificate. Such data must be recorded only where strictly necessary, must not be copied into general-purpose systems, and must never be included in an analytical dataset or a prompt to an external model.

## **Data Minimisation**

Systems must collect the least data that satisfies the purpose. Where a coarser value answers the question, the coarser value must be used.

Applied examples:

- Web analytics records country and city rather than precise location, and

stores a salted hash of the visitor address rather than the address itself.

- Support agents record the outcome of a case, not the full contents of an

unrelated conversation.

- Reporting on return behaviour uses counts and rates, not customer identities,

unless a specific fraud review is open.

- Demand forecasting uses aggregate sales by product, site, and period. It never

requires customer identity, and requests for customer-level forecasting data are refused.

A hash is a reduction in risk, not an elimination of it. Hashed identifiers remain personal data where the input space is small enough to enumerate. An IPv4 address has roughly four billion possibilities, which is trivially enumerable, so a hashed IP must be salted with a secret and must still be protected as personal data.

## **Retention**

| Data type                         | Retention                        | Action on expiry          |
|-----------------------------------|----------------------------------|---------------------------|
| Order and sales records           | 10 years                         | Retained for tax purposes |
| Support transcripts               | 24 months                        | Deleted                   |
| Web analytics records             | 14 months                        | Deleted                   |
| Fraud review case files           | 36 months                        | Deleted unless legal hold |
| Agent execution traces            | 12 months                        | Deleted                   |
| Marketing consent records         | Duration of consent plus 3 years | Deleted                   |
| Recruitment records, unsuccessful | 6 months                         | Deleted                   |
| Employee records                  | Per employment law               | Per employment law        |
| CCTV at warehouse sites           | 30 days                          | Overwritten               |

Retention periods are maximums, not targets. Data no longer needed for its original purpose should be deleted before the limit. Retention is enforced by scheduled deletion, not by individual judgement, because manual deletion at scale is never performed consistently.

A legal hold suspends deletion for the data covered by the hold. Holds are issued by Compliance in writing and lifted the same way.

## Access Control Principles

Access is granted by role and by need, and is read-only wherever a read satisfies the purpose.

Analytical and agent systems connect to the database through a read-only role. That role may run queries that select data. It may not insert, update, delete, or alter schema, and it may not read tables containing raw payment data. This restriction is enforced at the database level, not merely by convention, because a restriction that depends on a system behaving correctly is not a restriction at all.

Administrative interfaces require separate credentials from ordinary user accounts. Shared administrative credentials must be rotated whenever a person with access leaves.

Access is reviewed quarterly. The review confirms that every account still corresponds to a current employee in a role requiring that access. Accounts belonging to leavers are disabled on the final working day, not at the next review.

### *Privileged access*

Write access to production data is limited to named individuals in engineering and operations roles. Every use is logged. Bulk modification of customer or order records requires a second person's approval, recorded before the change.

## AI Agent Governance

Automated agents operate under the following constraints.

### **Agents may:**

- Query business data through the approved read-only path

- Retrieve and cite company documents
- Perform calculations and produce charts and reports from retrieved data
- Draft customer communications for human review

**Agents may not:**

- Modify any business record
- Execute code outside the approved sandbox
- Access raw payment data or full card identifiers
- Make a final decision on a refund, a price, or a customer's account status
- Contact a customer directly without human review
- Retain or transmit personal data outside approved systems

**Agents must:**

- Ground every factual claim in retrieved data or a cited document
- State when a figure is estimated rather than retrieved
- State when the available data does not answer the question
- Record which tools were used, with inputs and outcomes, for later review

***Input validation***

Requests to an agent are validated before execution. A request that attempts to extract bulk personal data, to modify records, or to bypass the constraints above is refused and recorded. Refusals are reviewed periodically, because a pattern of similar refused requests usually indicates either a legitimate need that lacks a proper route, or an attempt to misuse the system.

***Sandboxed execution***

Code generated by a model runs in an isolated environment with no network access, no access to the file system beyond a scoped working directory, and a wall-clock limit. The sandbox exists because model-generated code cannot be reviewed line by line at the speed it is produced, so containment substitutes for review.

**Grounding and Fabrication**

An agent that produces a plausible figure without a source has failed, even when the figure happens to be correct. Fabricated numbers are more damaging than refusals because they are indistinguishable from real ones at a glance, and because they are acted on.

Where an agent cannot retrieve the data needed, the correct response is to say what is missing and what would be required. It is never acceptable to fill the gap with an assumption presented as fact.

Where a retrieved figure conflicts with a document, both must be reported along with the conflict, rather than silently choosing one. The person reading the answer is better placed to resolve the conflict than the system is.

**Human Review Requirements**

The following always require a human decision, regardless of how confident an automated system is:

- Any refund, credit, or price change
- Any communication sent to a customer
- Any change to stock records or purchase orders
- Any conclusion in a fraud review
- Any statement to a regulator or authority

Automated output supporting these decisions is advisory. The reviewing human is accountable for the outcome, which means the output must be legible enough to review. An unexplainable recommendation cannot be approved, and a reviewer who cannot follow the reasoning should reject it rather than defer to it.

### ***Automated decision-making***

The GDPR gives individuals the right not to be subject to a decision based solely on automated processing where it produces legal or similarly significant effects. The company does not make such decisions automatically. Fraud reviews, account restrictions, and refund refusals are all decided by a person.

## **Audit and Traceability**

Every automated interaction with business data is recorded with the tools invoked, the time taken, the volume of data processed, and the resulting cost. These records exist so that any answer can be reconstructed after the fact.

Trace records are themselves subject to this policy. They may contain fragments of customer queries and are retained for 12 months.

Audit records are append-only. No role has permission to delete or alter them, including administrators, because an audit trail that privileged users can edit provides no assurance.

## **Third-Party Processing**

Data may only be sent to an external processor where a processing agreement exists and the transfer is documented. Model providers used for language processing are external processors.

Personal data must not be included in prompts to external providers unless the processing agreement covers it and the purpose requires it. Where a task can be performed on pseudonymised or aggregate data, it must be.

### ***Register of processors***

Compliance maintains a register recording, for each processor: the categories of data, the purpose, the location of processing, the transfer mechanism where processing occurs outside the European Economic Area, the contract date, and the review date. Engaging a processor not on the register is a policy breach.

### ***International transfers***

Transfers outside the EEA require an adequacy decision, standard contractual clauses, or another approved mechanism. Where standard contractual clauses are relied on, a transfer impact assessment is recorded.

### ***Sub-processors***

Processors must disclose sub-processors and give notice before adding one. A processor that changes sub-processors without notice is in breach, and the relationship is reviewed.

## Security Measures

- Data is encrypted in transit using current TLS, and at rest at the storage layer.
- Credentials and API keys are held in a secrets manager, never in source code,

configuration files, or messages.

- Multi-factor authentication is required on every account that supports it.
- Production and development environments are separated. Production personal

data is never copied into development; test data is synthetic.

- Dependencies are scanned for known vulnerabilities, and critical findings are

remediated within seven days.

- Backups are encrypted and tested by restoration at least annually. An untested

backup is an assumption, not a control.

## Breach Response

Any suspected exposure of personal data must be reported to Compliance immediately, and never later than 24 hours after discovery. Do not attempt to assess severity before reporting; that assessment is Compliance's to make.

The report must state what data was involved, how many people are affected if known, when the exposure began, and whether it is ongoing. Uncertainty on any of these points is not a reason to delay the report.

### *Regulatory timeline*

A personal data breach likely to result in a risk to individuals must be notified to the supervisory authority within 72 hours of the company becoming aware of it. Where the risk is high, affected individuals must also be informed without undue delay.

The 72 hours run from awareness, not from the completion of the investigation. A partial notification within the deadline is correct; a complete notification after it is not.

### *Response sequence*

- Contain, by revoking access, disabling the route, or isolating the system
- Assess what data was exposed, to whom, and for how long
- Notify Compliance, which decides on regulatory and individual notification
- Remediate the underlying cause
- Record the incident, the decisions taken, and the reasoning

Step 5 applies even where no notification was required. The reasoning for deciding not to notify must be recorded, because that decision may later need to be defended.

## Individual Rights

Customers may request access to their data, correction of it, deletion of it, restriction of processing, portability, or object to processing. Requests are answered within 30 calendar days, extendable by two further months for complex requests where the individual is told of the extension and the reason.

| Right         | Practical effect                                                               |
|---------------|--------------------------------------------------------------------------------|
| Access        | A copy of their personal data and information about its processing             |
| Rectification | Correction of inaccurate data, and completion of incomplete data               |
| Erase         | Deletion where no overriding basis to retain exists                            |
| Restriction   | Processing paused while a dispute over accuracy or basis is resolved           |
| Portability   | Data provided in a structured, machine-readable format                         |
| Objection     | Processing based on legitimate interests stops unless overriding grounds exist |

Requests are verified before being fulfilled. Sending someone else's data to a person who has impersonated them is itself a breach, and the verification step is the control that prevents it.

Deletion requests do not override the 10-year retention on transactional records required for tax purposes. Where a request cannot be fully honoured, the response must explain which data is retained and on what legal basis.

No fee is charged, except where a request is manifestly unfounded or excessive, in which case a reasonable administrative fee may be applied or the request refused with an explanation of the right to complain.

## Privacy by Design

New systems and material changes to existing ones require a privacy review before they are built, not before they launch. The review considers what personal data is involved, whether it is necessary, how long it is kept, who can access it, and what happens when it is no longer needed.

A data protection impact assessment is required where processing is likely to result in a high risk, including large-scale processing, systematic monitoring, or the use of new technology in a way individuals would not expect.

## Training and Accountability

Every employee completes data protection training on joining and annually thereafter. Roles with routine access to personal data receive additional role-specific training.

Compliance maintains the record of processing activities required by Article 30 and reviews it at least annually.

Failure to follow this policy is a disciplinary matter. Deliberate unauthorised access to personal data, and disclosure of personal data outside approved channels, are treated as gross misconduct.



## Document Control

| Field           | Value                   |
|-----------------|-------------------------|
| Version         | 2026.1                  |
| Effective date  | 2026-01-01              |
| Last reviewed   | 2026-01-01              |
| Next review due | 2027-01-01              |
| Owner           | Compliance              |
| Approved by     | Data Protection Officer |
| Classification  | Internal                |

This document is reviewed annually, and sooner if a change in law, supplier arrangement, or operating practice makes part of it inaccurate. The version published internally is the controlled copy; printed copies are uncontrolled. Proposed changes go to the document owner.